

Relatório de Resposta a Incidente

Investigação de Browser Hijacker / Banking Trojan via extensão maliciosa no Google Chrome

Caso: extensão maliciosa “Receita Federal” com persistência por política/cloud policy do Chrome

Campo	Valor
ID do incidente	INC-2026-05-26-CHROME-EXT
Data do relatório	26/05/2026
Severidade	Alta / Crítica
Tipo de incidente	Malware, browser hijacker, abuso de extensão, roubo de sessão e risco de fraude bancária
Ambiente afetado	Endpoint Windows com Google Chrome
Status	Causa técnica identificada. Erradicação definitiva depende de validação pós-limpeza/reinstalação.
Classificação do documento	Sanitizado para portfólio / LinkedIn. Evidências completas devem permanecer em repositório privado.

Aviso de publicação
Este relatório foi sanitizado. Não publicar nomes reais de usuários, hostnames internos, e-mails pessoais, dados bancários, prints com informações sensíveis, cookies, tokens, arquivos executáveis ou amostras do malware.

Controle do documento

Campo	Valor
Versão	2.0 - Reestruturada para resposta a incidente / SOC
Origem	Relatório técnico original e evidências citadas pelo analista
Objetivo	Transformar a investigação em relatório operacional, rastreável e acionável para SOC/IR
Escopo da edição	Reorganização, padronização de linguagem, matriz de evidências, IOCs, ações por fase e apêndices técnicos
Observação	Nenhuma amostra foi executada durante a análise assistida. O vetor inicial permanece não confirmado.

Índice do relatório

- 1. Sumário executivo
 - 2. Escopo, premissas e limitações
 - 3. Severidade, impacto e risco
 - 4. Linha do tempo operacional
 - 5. Metodologia de investigação
 - 6. Evidências analisadas
 - 7. Achados confirmados
 - 8. Análise técnica da extensão maliciosa
 - 9. Mecanismo de persistência e reinfecção
 - 10. Hipóteses, descartes e pendências
 - 11. Indicadores de comprometimento
 - 12. Ações de contenção, erradicação e recuperação
 - 13. Detecção e hunting para SOC
 - 14. Mapeamento MITRE ATT&CK
 - 15. Resultado final e lições aprendidas
 - 16. Resumo publicável
- Apêndices técnicos

1. Sumário executivo

Foi investigado um incidente em endpoint Windows envolvendo sequestro de navegador e reinstalação persistente de uma extensão maliciosa no Google Chrome. A extensão se apresentava como “Receita Federal” e retornava após remoção manual quando o computador era reconectado à rede.

A investigação confirmou que o mecanismo ativo de reinfecção estava relacionado a uma política/cloud policy do Chrome no perfil do usuário. Essa política continha a extensão lcnbblofcdgbkjhheceldgmhldlfoaij e o update_url <https://certicado.com/update.xml>, permitindo que a extensão fosse baixada ou reinstalada novamente.

O comportamento da extensão é compatível com banking trojan baseado em navegador. Foram identificadas permissões para cookies, scripting, abas e storage, além de scripts voltados a bancos, webmail, captura de inputs, captura de tela, overlays e comunicação com infraestrutura externa.

Pergunta executiva	Resposta
O que aconteceu?	Uma extensão maliciosa foi instalada no Chrome e retornava após remoção manual.
Qual foi o principal achado?	Persistência por política/cloud policy do Chrome contendo a extensão e update_url externo.
Qual o risco?	Fraude bancária, roubo de sessão, captura de cookies, inputs, screenshots e interferência em webmail/bancos.
A causa da reinfecção foi identificada?	Sim. A reinfecção foi atribuída ao arquivo User Data\Policy\Machine Level User Cloud Policy.
O vetor inicial foi provado?	Não. Há suspeita de instalador/PUP/downloader ou abuso de gerenciamento do Chrome, mas sem prova conclusiva.
Recomendação principal	Reinstalação limpa do Windows ou remoção completa de policy/perfil/extensão, varredura offline e validação controlada.

1.1 Classificação do incidente

Critério	Avaliação
Severidade	Alta / Crítica
Confiança da atribuição técnica	Alta para a extensão e política/cloud policy. Média/baixa para vetor inicial.
Ativos afetados	Endpoint Windows, perfil do Chrome, sessões web, credenciais e possíveis acessos bancários/webmail.
Dados em risco	Cookies, sessões, inputs digitados, telas visíveis e dados de autenticação em páginas-alvo.
Estado final da investigação	Causa técnica da reinfecção identificada. Erradicação definitiva pendente de validação pós-limpeza.

2. Escopo, premissas e limitações

2.1 Escopo analisado

- Relatórios gerados por scripts PowerShell de triagem e threat hunting.
- Perfil do Google Chrome, incluindo User Data, Secure Preferences, Extensions, Local Extension Settings e Policy.
- Consultas de registro relacionadas a políticas do Chrome, extensões externas, Run/RunOnce, Winlogon e PreferenceMACs.
- Pastas e artefatos suspeitos em ProgramData, AppData, Temp, Windows\Tasks e System32\Tasks.
- Strings e hashes de artefatos selecionados, sem execução de amostras maliciosas.

2.2 Premissas

- Os dados pessoais foram pseudonimizados para publicação.
- Caminhos de usuário foram representados como C:\Users\[usuario]\... sempre que possível.
- A análise priorizou evidências preservadas e verificáveis por arquivo, hash, manifesto, política, strings e relatório.
- O relato visual de janela CMD com referência a NinjaRT/NinjaRtt foi tratado como observação operacional, não como confirmação técnica.

2.3 Limitações

- Não houve execução dinâmica da extensão ou de executáveis suspeitos em sandbox durante a análise assistida.
- A amostra inicial responsável por configurar a política/cloud policy não foi preservada de forma conclusiva.
- A remoção manual anterior alterou parte do estado do ambiente antes da coleta final.
- Sem validação após limpeza ou reinstalação, não é correto afirmar que o sistema operacional voltou a ser confiável.

3. Severidade, impacto e risco

Dimensão	Avaliação	Justificativa
Confidencialidade	Crítica	Permissões e código indicam captura de cookies, storage, inputs e telas.
Integridade	Alta	A extensão podia injetar overlays, modais e scripts em páginas bancárias/webmail.
Disponibilidade	Média	Não houve evidência de criptografia ou destruição, mas havia risco de bloqueio/interferência na sessão.
Fraude financeira	Crítica	Alvos incluíam Bradesco, Banco do Brasil, Caixa e webmail.
Persistência	Alta	Reinstalação após remoção manual por política/cloud policy do Chrome.
Decisão de severidade O incidente foi classificado como Alta / Crítica porque o artefato confirmado tinha foco em bancos e webmail, acesso a cookies/sessões, capacidade de captura/interferência e mecanismo de reinstalação persistente.		

4. Linha do tempo operacional

Fase	Evento	Evidência/observação	Decisão SOC
0	Sintomas iniciais	Extensão "Receita Federal" controlava o Chrome, retornava após reboot/conexão e havia abertura rápida de CMD com referência visual a NinjaRT/NinjaRtt.	Isolar endpoint e tratar como incidente de malware com risco alto.
1	Relatório inicial	Hipótese de browser hijacker com possível RAT/persistência.	Priorizar coleta, troca de credenciais e preservação de evidências.
2	Triagem passiva	Execução de script para varrer evidências, hashes, strings, tarefas, extensões e artefatos recentes.	Separar achados de alto ruído dos artefatos relevantes.
3	Primeiros achados	uhelper.exe em ProgramData\wDclibs, executável anômalo em ProgramData\USOShared e tarefas update-sys/update-SID.	Priorizar análise de strings, tarefas e origem de downloads.
4	Análise de details.log	Registro de download de DclibsSetup.exe a partir de download.cdconver.com, MD5 48da8139ecad382bda4779b1e16aed41.	Manter wDclibs/uhelper como IOC auxiliar suspeito.

5	Strings de uhelper.exe	Indícios de comportamento de downloader/updater e comunicação HTTP.	Não atribuir relação direta com a extensão sem prova adicional.
6	Tarefas .job	update-sys.job apontava para Skillbrains Updater.	Reclassificar como baixa prioridade para este incidente.
7	Estado antes da reconexão	Sem extensão ativa e sem ExtensionInstallForcelist clássico no Registro.	Investigar perfil do Chrome e persistência não clássica.
8	Reconexão controlada	Comportamento retornou após conexão à rede.	Capturar estado reinfectado.
9	Extensão capturada	Extensão Receita Federal, ID lcnbblofcdgbkjhhecldgmhdfjoaij, versão 11.0.0, update_url certificado.com.	Confirmar foco em browser extension abuse.
10	User Data analisado	Machine Level User Cloud Policy continha extensão e update_url.	Fechar causa técnica da reinfecção.
11	Conclusão	Banking trojan via extensão maliciosa com persistência por política/cloud policy.	Executar contenção, erradicação, recuperação e validação pós-limpeza.

5. Metodologia de investigação

A investigação combinou triagem forense leve, análise de configuração de navegador, análise de persistência Windows e comparação entre o estado antes e depois da reconexão à rede. A validação comparativa foi decisiva para capturar a extensão recriada.

Técnica	Uso no caso
Coleta controlada	Compactação e preservação de pastas relevantes, evitando coleta indiscriminada de senhas, cookies e documentos pessoais.
Hashing	Cálculo de hashes para arquivos suspeitos e artefatos da extensão.
Strings	Extração passiva de strings em .job e executáveis para identificar comandos, URLs e indicadores.
Registro Windows	Consulta de HKLM/HKCU Policies, Run/RunOnce, External Extensions, Chrome Enrollment e PreferenceMACs.
Chrome User Data	Análise de Extensions, Secure Preferences, Local Extension Settings, Policy e Machine Level User Cloud Policy.
Tarefas agendadas	Revisão de Windows\Tasks e System32\Tasks, incluindo .job binário.
Navegadores	Revisão de manifest.json, permissões, host_permissions, service_worker e content_scripts.
Comparação offline/reconectado	Comparação entre estado sem rede e estado após reconexão para identificar mecanismo de retorno.

5.1 Scripts e comandos usados

Artefato	Finalidade	Uso na conclusão
Scan-Evidence.ps1	Triagem passiva de evidências, hashes, strings, tarefas, extensões e artefatos recentes.	Apoio à triagem inicial.
Analise-HD-Malware-Offline-Live.ps1	Análise de registro, tarefas e extensões em modo offline e live.	Importante para comparar estado antes/depois da reconexão.
FullDisk-ThreatHunt-Hijacker-RAT.ps1	Threat hunting amplo em disco.	Não usado como evidência final porque não executou corretamente no ambiente.

Comandos específicos	Strings de .job/uhelper, consultas de política Chrome e busca por certificado.com/ID da extensão.	Apoio direto à confirmação da persistência.
----------------------	---	---

6. Evidências analisadas

A tabela abaixo consolida as evidências de maior valor para resposta a incidente. O status indica como cada item foi usado na conclusão.

ID	Evidência	Tipo	Relevância	Status
EV-01	Relatorio_Incidente_Malware_Hijacker_RAT.docx	DOCX	Base inicial, sintomas, hipóteses e recomendações.	Preservado
EV-02	findings_suspicious.csv / hashes_all_files.csv	CSV	Triagem ampla com arquivos analisados e achados heurísticos.	Preservado
EV-03	job_strings_update-sys.txt	TXT	Strings de tarefa .job.	Reclassificado como baixa prioridade
EV-04	strings_uhelper_powershell.txt	TXT	Strings de uhelper.exe e comportamento de downloader/updater.	IOC auxiliar suspeito
EV-05	Analise_HD_Malware_20260526_152504.zip	ZIP	Estado antes da reinfeção, sem extensão ativa.	Comparativo
EV-06	Analise_HD_Malware_20260526_155737.zip	ZIP	Estado após reconexão com extensão ativa.	Evidência-chave
EV-07	chrome_receita_external_registry.try.txt	TXT	Consulta de registro externa sem chaves clássicas de extensão.	Suporte à conclusão
EV-08	User Data.zip	ZIP	Perfil do Chrome, extensão, Secure Preferences e policy.	Evidência principal
EV-09	Chrome.zip	ZIP	Instalação do Chrome em Program Files.	Não origem principal

6.1 Classificação das evidências

Classificação	Definição	Exemplo no caso
Confirmada	Evidência direta por arquivo, manifesto, política, hash ou log.	Extensão Receita Federal e Machine Level User Cloud Policy.
Suspeita	Artefato ou comportamento anômalo, mas sem vínculo técnico final confirmado.	wDcLibs/uhelper.exe e ProgramData\USOShared.
Baixa prioridade	Item inicialmente suspeito, mas reclassificado por contexto técnico.	update-sys.job apontando para Skillbrains Updater.
Observação operacional	Relato ou sintoma observado, sem amostra/hash/log suficiente.	Referência visual a NinjaRT/NinjaRtt em janela CMD.

7. Achados confirmados

7.1 Achado 1 - Extensão maliciosa no Google Chrome

Campo	Valor
Nome exibido	Receita Federal
ID	lcnbblofcdgbkjhhcecldgmhdlfjoaij
Versão	11.0.0
Descrição declarada	Sistema de controle para emissao de notas fiscais
Update URL	https://certicado.com/update.xml
Estado no Secure Preferences	from_webstore=false; ack_external=true; location=7; path=lcnbblofcdgbkjhhcecldgmhdlfjoaij\11.0.0_0
Caminho	C:\Users\[usuario]\AppData\Local\Google\Chrome\User Data\Default\Extensions\lcnbblofcdgbkjhhcecldgmhdlfjoaij\11.0.0_0

7.2 Achado 2 - Persistência por política/cloud policy

Campo	Valor
Arquivo	User Data\Policy\Machine Level User Cloud Policy
Tipo observado	google/chrome/machine-level-user
Extensão forçada/gerenciada	lcnbblofcdgbkjhhcecldgmhdlfjoaij;https://certicado.com/update.xml
Configuração adicional	toolbar_pin: force_pinned
Contato/domínio observado	suporte@certicado.com / certificado.com
Arquivo auxiliar	Machine Level User Cloud Policy Signing Key
Conclusão	A política explica o retorno da extensão após remoção manual e reconexão à rede.

7.3 Achado 3 - Foco em bancos e webmail

Categoria	Evidência
Bancos	host_permissions e scripts direcionados a Bradesco, Banco do Brasil, Caixa e Bradesco Net Empresa.
Webmail	content-inputs.js com foco em UOL, Locaweb e webmail-seguro.
Captura de sessão	Uso de permissões cookies/storage e funções para coleta de localStorage/sessionStorage.
Interferência em páginas	Overlays e modais falsos para tokens, QR Code, loading e travamento de sessão.
Comunicação externa	ws.servidorway.com e cobrowse.io.

8. Análise técnica da extensão maliciosa

8.1 Manifesto, permissões e scripts

Item	Valor
background.service_worker	background.js
content_scripts	socket.io.min.js, CobrowseIO.js, content-bradesco.js, cobrowse-init.js, content-bancos.js, content-inputs.js
permissions	tabs, storage, activeTab, scripting, cookies
host_permissions	<all_urls>; Bradesco; Banco do Brasil; Caixa; UOL; webmail-seguro; ws.servidorway.com; cobrowse.io
web_accessible_resources	Arquivos HTML/CSS/imagens de overlays/modais bancários, incluindo BB, Bradesco, Caixa e Net Empresa.

8.2 Comportamentos observados no código JavaScript

Arquivo/Grupo	Comportamento identificado
background.js	Uso de chrome.tabs.captureVisibleTab para screenshot; chrome.cookies.getAll para cookies; coleta de localStorage/sessionStorage.
content-bradesco.js	Conexão socket.io com https://ws.servidorway.com; comandos para screenshot, cookies, inputs e interação com páginas Bradesco/Caixa.
content-bancos.js	Foco em Banco do Brasil, Caixa e Bradesco Net Empresa; modais de QR Code, token celular, token dispositivo, senhas e travas de tela.
content-inputs.js	Foco em UOL, Locaweb e webmail-seguro; captura de inputs e comunicação com servidor remoto.
cobrowse-init.js	Inicialização de CobrowseIO, ocultação de controles e suporte a interação remota/co-browse.
overlays/*.html	Telas falsas e modais para bancos, QR Code, tokens, loading e trava de sessão.

8.3 Interpretação técnica

A extensão demonstrou comportamento compatível com banking trojan baseado em navegador. Os recursos observados permitem acesso a cookies e storage, captura de telas, coleta de inputs, injeção de overlays, foco em domínios bancários e webmail, além de comunicação com infraestrutura externa.

A presença de CobrowseIO e socket.io sugere capacidade de acompanhamento ou interação remota com sessões de interesse. O uso do nome “Receita Federal” e de descrição relacionada a notas fiscais indica masquerading e engenharia social para reduzir suspeita do usuário.

8.4 Hashes dos arquivos principais da extensão

Arquivo	SHA256
manifest.json	DA3BFC211CA846893BDBE1B0B1EF5973D1E7015E5EDB60D449CF6ABF20D5C8AA
background.js	9DA1649842ED620D47C2CC03450653223455479E8F271CC0C6EF1AD397F1F62A
content-bradesco.js	FE489F142CD2634722311A8F6BA061D90FBA8E9480F99B4A25D37D5DB43FA8F4
content-bancos.js	7C5B800885EF6AE0266F4DAD6181DE3853BD760D5A186ED18470B53D198791B5
content-inputs.js	BDE63DC73B12193FB7AAA719DD761EDE51A9D93108FEE2CACA438AF0CF648C3D

cobrowse-init.js	CF73E2235CC98790BC357C8201741FE04C11018ADF9CC2E086529F04AD2E74AF
socket.io.min.js	D89B054AE27D0AA4FF93A13657A87DE9518F21C615D771917AA2B494389E1F58
CobrowseIO.js	14BF6FD179210CF9A74AADFC36DBD59491C3D0C869F92221A5E031FF15589EE3

9. Mecanismo de persistência e reinfecção

A descoberta decisiva foi que a extensão retornava após conexão porque o perfil do Chrome continha uma política local/cloud policy com instrução para instalar a extensão a partir de um update_url externo.

Fluxo observado:

Endpoint conecta à rede

- > Chrome abre ou executa processos auxiliares
- > Chrome lê/sincroniza Machine Level User Cloud Policy
- > Política contém: lcnbblofcdgbkjhhceeldgmhldfjoaij;https://certicado.com/update.xml
- > Chrome baixa ou atualiza a extensão “Receita Federal”
- > Extensão injeta scripts em bancos/webmail
- > Comunicação com ws.servidorway.com e cobrowse.io

9.1 Por que o Registro clássico não mostrou a origem

As consultas em HKCU\HKLM\Software\Google\Chrome\Extensions e WOW6432Node não encontraram a extensão. Esse resultado é coerente com a conclusão final: o mecanismo não era o método clássico de extensão externa via Registro, e sim política/cloud policy no perfil do Chrome.

Item verificado	Resultado	Interpretação
HKCU\HKLM Chrome Extensions	Sem correspondência para o ID ou certificado.com.	Não havia external extension clássica via Registro.
ExtensionInstallForcelist	Sem política clássica local no momento da coleta.	A persistência estava em outro mecanismo.
PreferenceMACs	ID encontrado em HKCU\Software\Google\Chrome\PreferenceMACs\Default\extensions.settings.	Confirma registro da extensão no perfil, mas não sua origem.
Machine Level User Cloud Policy	Continha ID da extensão e update_url.	Evidência direta da reinfecção.

9.2 Causa raiz técnica

Causa raiz confirmada

A reinfecção ocorria porque o Chrome lia uma política/cloud policy persistida no perfil do usuário. A política continha o ID da extensão e o update_url externo, permitindo reinstalação após remoção manual e reconexão à rede.

9.3 Vetor inicial provável

Não foi possível provar qual instalador, processo ou ação inicial inseriu o navegador em estado gerenciado. A hipótese mais forte é que um instalador/PUP/downloader anterior configurou a política/cloud policy e, depois disso, a extensão passou a ser baixada ao reconectar.

Hipótese	Descrição	Confiança
A	Instalador malicioso/PUP configurou a política/cloud policy e habilitou a reinstalação da extensão.	Média
B	Software remoto/RMM ou componente associado	Baixa

	ao relato NinjaRemote/NinjaRT foi usado como vetor auxiliar.	
C	Sincronização de navegador/conta contribuiu para preservar o estado.	Baixa a média

10. Hipóteses, descartes e pendências

Item	Evidência	Classificação	Motivo
Extensões do Edge	Google Docs Offline e Edge relevant text changes.	Baixa prioridade	Sem relação com Receita Federal; update_urls oficiais/comuns.
update-sys.job	C:\Program Files (x86)\Skillbrains\Updater\Updater.exe -runmode=checkupdate.	Baixa prioridade	Nome/timestamp suspeitos, mas sem vínculo com wDcLibs/Chrome/Receita.
Policies\Google\Chrome	HKLM/HKCU e ExtensionInstallForcelist.	Sem achado clássico	Não havia forcelist local clássica no Registro no momento da coleta.
Chrome.zip	Pasta do Chrome em Program Files.	Não origem principal	Extensão e política estavam no perfil User Data.
Warsaw/TPZ	warsaw_setup_64.exe / .wtcf.	Revisar, não principal	Provável módulo bancário/segurança; não explicou reinfeção.
Defender/OneDrive/Malwarebytes	Muitos HIGH heurísticos.	Falsos positivos prováveis	Marcados por strings internas, assinaturas e caminhos coerentes.
ProgramData\USOShared	Executável com nome/pasta aleatória e assinatura NVIDIA.	Pendente	Anomalia a validar, sem relação final comprovada.
NinjaRT/NinjaRtt	CMD observado e pasta NinjaRemote vazia.	Observação operacional	Sem artefato preservado suficiente para confirmar RAT por hash/amostra.

10.1 Pendências recomendadas

- Validar se há políticas de Chrome Enrollment ou CloudManagementEnrollmentToken ainda presentes no host.
- Validar se a conta Google sincronizou extensões ou configurações suspeitas.
- Executar varredura offline e EDR completo antes de qualquer reconexão permanente.
- Confirmar se outros endpoints consultaram certicado.com, ws.servidorway.com, cobrowse.io ou download.cdconver.com.
- Preservar e submeter wDcLibs/uhelper.exe para análise estática/dinâmica em ambiente controlado, caso permitido.

11. Indicadores de comprometimento

11.1 IOCs confirmados

Tipo	Indicador	Observação
Extensão	lcnbblofcdgbkjhheceldgmhdfjoaij	ID da extensão maliciosa no Chrome.
Nome	Receita Federal	Nome exibido para engenharia social.
URL	https://certicado.com/update.xml	Update URL da extensão.
Domínio	certicado.com	Domínio observado em policy e update_url.
URL/Domínio	https://ws.servidorway.com	Comunicação socket/C2 observada no código.
URL/Domínio	https://cobrowse.io	Serviço de co-browse/interação remota referenciado.
Caminho	C:\Users\[usuario] \AppData\Local\Google\Chrome\User Data\Policy\Machine Level User Cloud Policy	Política responsável pela reinfeção.

Caminho	C:\Users\[usuario] \AppData\Local\Google\Chrome\User Data\Default\Extensions\lcnbblofcdgbkjhhceeldgmhdfjoaij\11.0.0.0_0	Pasta da extensão.
---------	---	--------------------

11.2 IOCs auxiliares/suspeitos

Tipo	Indicador	Observação
Arquivo	C:\ProgramData\wDcLibs\uhelper.exe	IOC auxiliar suspeito, sem vínculo final comprovado com a extensão.
SHA256	A9EF1395604E61EA3AF0F4D04B2EDFA41A35568B392EB374299544B064950F7A	Hash de uhelper.exe.
Arquivo	details.log	Registrou download relacionado a wDcLibs.
SHA256	36B171470FE98FD4E6F9A44780380DFD7894FB8322D98E7CCC1DF7197236C9B6	Hash de details.log.
Domínio	download.cdconver.com	Domínio observado em details.log.
Domínio	cdconver.com	Domínio raiz associado.
Arquivo	DcLibsSetup.exe	Arquivo baixado segundo details.log; não preservado na coleta final.
MD5	48da8139ecad382bda4779b1e16aed41	MD5 observado para DcLibsSetup.exe.

11.3 Lista rápida para bloqueio

certificado.com
 https://certificado.com/update.xml
 ws.servidorway.com
 https://ws.servidorway.com
 cobrowse.io
 https://cobrowse.io
 download.cdconver.com
 cdconver.com

12. Ações de contenção, erradicação e recuperação

12.1 Contenção imediata

Prioridade	Ação	Objetivo
P0	Isolar o endpoint da rede.	Evitar reinstalação, comunicação C2 e movimentação adicional.
P0	Bloquear uso do host para banco, webmail, certificado digital e troca de senhas.	Evitar captura de novas credenciais ou sessões.
P0	Preservar User Data.zip, extensão, policy, hashes, relatórios e wDcLibs antes da remoção.	Manter cadeia de evidência e reprodutibilidade.
P1	Bloquear IOCs em DNS, proxy, firewall e EDR.	Reduzir risco de callback e atualização.
P1	Revogar sessões e tokens de contas usadas no endpoint.	Reduzir impacto de cookies/sessões comprometidas.
P1	Forçar troca de senhas a partir de dispositivo limpo.	Conter comprometimento de credenciais.

12.2 Erradicação técnica

A remoção deve ser feita offline e somente após preservação das evidências. Excluir apenas a extensão não resolve quando a policy permanece.

1. Encerrar chrome.exe e processos auxiliares do Google Chrome.
2. Preservar pasta da extensão, User Data\Policy, Secure Preferences e wDcLibs.
3. Renomear o perfil antigo: User Data -> User Data.INFECTADO_BACKUP.
4. Remover User Data\Policy, incluindo Machine Level User Cloud Policy e Machine Level User Cloud Policy Signing Key.
5. Remover a extensão lcnbblofcdgbkjheceldgmhldfjoaij de Default\Extensions e Local Extension Settings.
6. Limpar chaves de gerenciamento/políticas do Chrome quando presentes, incluindo CloudManagementEnrollmentToken e Chrome Enrollment.
7. Quarentenar C:\ProgramData\wDcLibs após preservação.
8. Executar Microsoft Defender Offline, EDR corporativo e ferramenta anti-adware confiável, conforme política da organização.
9. Reabrir Chrome sem login/sync e validar chrome://management, chrome://policy e chrome://extensions.

12.3 Recuperação

10. Recriar perfil limpo do Chrome.
11. Reautenticar contas somente após troca de senhas e revisão de MFA.
12. Não restaurar AppData, perfil antigo do Chrome, extensões, scripts, cracks, ativadores ou instaladores antigos.
13. Monitorar DNS/proxy/EDR para qualquer nova tentativa de acesso aos IOCs.
14. Validar o comportamento após reconexão controlada à rede.
15. Documentar evidência de ausência da extensão e ausência de policy maliciosa.

12.4 Recomendação mais segura

Reinstalação limpa recomendada

Devido ao foco em bancos, webmail, cookies, screenshots e inputs, a medida mais segura é reinstalação limpa do Windows, com restauração seletiva apenas de documentos. Não restaurar perfis de navegador, AppData, extensões, executáveis, scripts, cracks/ativadores ou instaladores antigos.

12.5 Prevenção

Camada	Medida preventiva
Navegador	Usar allowlist de extensões; bloquear extensões fora da Chrome Web Store; monitorar chrome://management e chrome://policy.
Conta Google	Desativar sync de extensões temporariamente; revisar extensões sincronizadas; revogar sessões e apps conectados.
DNS/Firewall	Bloquear IOCs; ativar filtro DNS para malware/phishing e domínios recém-criados.
Endpoint	Manter EDR/antivírus atualizado; restringir execução em AppData, Temp e ProgramData.
Usuários	Treinar contra malvertising, instaladores falsos, cracks/ativadores, falsas notificações de órgãos públicos e extensões suspeitas.
Administração	Aplicar menor privilégio; remover admin local; auditar RMMs como Ninja, AnyDesk e TeamViewer.
Resposta a incidente	Coletar antes de remover; calcular hashes; criar timeline; validar após reconexão; separar achado confirmado de hipótese.

13. Detecção e hunting para SOC

As consultas abaixo são orientações práticas. Ajuste sintaxe e campos conforme SIEM, EDR, proxy, DNS ou ferramenta usada pela organização.

13.1 Busca em endpoint Windows

```
reg query "HKLM\SOFTWARE\Policies\Google\Chrome" /s
reg query "HKCU\SOFTWARE\Policies\Google\Chrome" /s
reg query "HKLM\SOFTWARE\Policies\Google\Chrome\ExtensionInstallForcelist" /s
reg query "HKCU\SOFTWARE\Policies\Google\Chrome\ExtensionInstallForcelist" /s
reg query "HKLM\SOFTWARE\Policies\Google\Chrome" /v CloudManagementEnrollmentToken
reg query "HKLM\SOFTWARE\Google\Chrome\Enrollment" /s
reg query "HKLM\SOFTWARE\WOW6432Node\Google\Enrollment" /s
reg query "HKCU\Software\Google\Chrome\PreferenceMACs\Default\extensions.settings" /s
```

13.2 Caminhos-chave para verificar

```
C:\Users\[usuario]\AppData\Local\Google\Chrome\User Data\Policy
C:\Users\[usuario]\AppData\Local\Google\Chrome\User Data\Default\Extensions\lcnbblofcdgbkjhheceldgmhdfjoaij
C:\Users\[usuario]\AppData\Local\Google\Chrome\User Data\Default\Local Extension Settings\lcnbblofcdgbkjhheceldgmhdfjoaij
C:\Users\[usuario]\AppData\Local\Google\Chrome\User Data\Default\Secure Preferences
C:\ProgramData\wDcLibs
```

13.3 Lógica de detecção sugerida

Fonte	Condição de alerta	Prioridade
DNS/Proxy	Acesso a certificado.com, ws.servidorway.com, cobrowse.io, download.cdconver.com ou cdconver.com.	Alta
EDR/File	Criação/modificação de User Data\Policy\Machine Level User Cloud Policy fora de janela administrativa conhecida.	Alta
EDR/File	Criação de pasta de extensão com ID lcnbblofcdgbkjhheceldgmhdfjoaij.	Alta
EDR/Registry	Alteração de políticas Chrome, Enrollment ou CloudManagementEnrollmentToken em endpoint não gerenciado.	Alta
EDR/File	Execução ou criação de C:\ProgramData\wDcLibs\uhelper.exe.	Média
SIEM/Identity	Login bancário/webmail ou mudança de MFA a partir de sessão comprometida.	Alta

13.4 Critérios de validação pós-limpeza

Validação	Resultado esperado
chrome://extensions	Extensão Receita Federal ausente.
chrome://policy	Sem política desconhecida forçando extensão ou update_url externo.
chrome://management	Chrome não aparece como gerenciado indevidamente.

User Data\Policy	Machine Level User Cloud Policy maliciosa ausente.
DNS/Proxy/EDR	Sem novos acessos aos IOCs após reconexão controlada.
Credenciais	Senhas trocadas a partir de dispositivo limpo e MFA revisado.

14. Mapeamento MITRE ATT&CK

Técnica	Nome	Aplicação no caso
T1176	Browser Extensions	Extensão maliciosa instalada/gerenciada no Google Chrome.
T1036	Masquerading	Nome "Receita Federal" e descrição de emissão de notas fiscais para parecer legítima.
T1113	Screen Capture	Uso de captura de tela da aba ativa.
T1539	Steal Web Session Cookie	Uso de API de cookies e coleta de sessão.
T1056	Input Capture	Scripts content-inputs/content-bancos capturam entradas digitadas.
T1105	Ingress Tool Transfer	details.log do wDcLibs registrou download de DcLibsSetup.exe.
T1053	Scheduled Task/Job	Tarefas .job foram investigadas; update-sys foi reclassificada como baixa prioridade.

15. Resultado final e lições aprendidas

15.1 Resultado final

Pergunta	Resposta
Por que a extensão voltava após remover e reconectar?	Porque o Chrome lia/sincronizava uma política/cloud policy contendo a extensão e update_url, reinstalando-a no perfil do usuário.
Qual foi o artefato ativo confirmado?	Extensão maliciosa do Chrome "Receita Federal", ID lcnbblofcdgbkjheceldgmhdlfjoaij.
Qual mecanismo explicou a reinfecção?	User Data\Policy\Machine Level User Cloud Policy.
O vetor inicial foi confirmado?	Não. Há suspeita de instalador/PUP/downloader ou abuso de gerenciamento do Chrome.
RAT/NinjaRT foi confirmado?	Não. O relato foi mantido como observação operacional, sem amostra final.
Qual resolução é recomendada?	Reinstalação limpa ou remoção completa de policy/perfil/extensão, varredura offline, troca de credenciais, bloqueios de rede e validação controlada.

15.2 Lições aprendidas

- Nem toda persistência de extensão aparece em ExtensionInstallForcelist clássico no Registro.
- Chrome User Data, Secure Preferences, Extension Settings e Machine Level User Cloud Policy devem fazer parte do playbook de investigação.
- Remover a extensão manualmente não basta quando existe política de gerenciamento reinstalando o artefato.
- Comparar o estado antes e depois da reconexão à rede pode revelar o mecanismo de reinfecção.
- Relatos do usuário são importantes, mas devem ser separados de evidências confirmadas por arquivo, hash, política ou log.
- Em incidentes com foco em bancos e webmail, a recuperação deve priorizar credenciais, sessões, tokens, MFA e reinstalação limpa.

16. Resumo publicável

Texto sugerido para publicação, sem expor dados sensíveis:

Conduzi uma investigação de incidente em endpoint Windows com comportamento de browser hijacker persistente. A extensão maliciosa se apresentava como “Receita Federal” e retornava após remoção manual quando o computador era reconectado à rede.

A análise evoluiu de uma hipótese inicial de RAT/hijacker para a identificação de uma extensão maliciosa no Google Chrome, instalada por política/cloud policy do navegador. A extensão possuía update_url externo, permissões para cookies, scripting e abas, além de foco em bancos e webmail, captura de inputs, screenshots e comunicação com infraestrutura remota.

O caso reforçou a importância de analisar não apenas Registro e tarefas agendadas, mas também Chrome User Data, Secure Preferences, Extension Settings e Machine Level User Cloud Policy. O resultado foi a identificação do mecanismo de reinfeção e a definição de um plano de contenção, erradicação, recuperação e prevenção.

Publicação segura

Publicar somente a versão sanitizada. Não incluir nomes de usuários, hostnames, prints de contas, dados bancários, amostras executáveis ou dados internos do cliente.

Apêndice A - Comandos de validação recomendados

```
reg query "HKLM\SOFTWARE\Policies\Google\Chrome" /s
reg query "HKCU\SOFTWARE\Policies\Google\Chrome" /s
reg query "HKLM\SOFTWARE\Policies\Google\Chrome\ExtensionInstallForcelist" /s
reg query "HKCU\SOFTWARE\Policies\Google\Chrome\ExtensionInstallForcelist" /s
reg query "HKLM\SOFTWARE\Policies\Google\Chrome" /v CloudManagementEnrollmentToken
reg query "HKLM\SOFTWARE\Google\Chrome\Enrollment" /s
reg query "HKLM\SOFTWARE\WOW6432Node\Google\Enrollment" /s
reg query "HKCU\Software\Google\Chrome\PreferenceMACs\Default\extensions.settings" /s
```

Caminhos-chave:

C:\Users\[usuário]\AppData\Local\Google\Chrome\User Data\Policy
 C:\Users\[usuário]\AppData\Local\Google\Chrome\User Data\Default\Extensions\lcnbblofcdgbkjhhceclgdmhldfjoaij
 C:\Users\[usuário]\AppData\Local\Google\Chrome\User Data\Default\Secure Preferences
 C:\ProgramData\wDcLibs

Apêndice B - Cadeia de custódia mínima

Campo	Preenchimento recomendado
ID da evidência	EV-XX
Descrição	Nome do arquivo/pasta/artefato
Origem	Host, usuário pseudonimizado, caminho e data/hora de coleta
Hash	SHA256 preferencialmente
Coletado por	Nome/pseudônimo do analista
Armazenamento	Repositório privado, controle de acesso e checksum
Observações	Alterações realizadas, ferramentas usadas e limitações

Apêndice C - Referências técnicas

Fonte	URL
Google Chrome Enterprise - ExtensionInstallForcelist	Abrir referência
Google Chrome Enterprise - ExtensionSettings	Abrir referência
Google Chrome - Cloud Management / Enrollment Token	Abrir referência
Google Chrome - CloudManagementEnrollmentToken policy	Abrir referência
Malwarebytes AdwCleaner	Abrir referência
Microsoft Defender Offline	Abrir referência
MITRE ATT&CK - Browser Extensions	Abrir referência
MITRE ATT&CK - Scheduled Task/Job	Abrir referência
NIST SP 800-61 Rev. 3 - Incident Response	Abrir referência